JAN. FEB. MAR. APR. MAY JUN. JUL. AUG. SEP. OCT. NOV. DEC.

CSA

Virtual Event

SERIES 2026

CSA | Virtual Event SERIES 2026

Trustworthy Agentic Commerce – in a Hybrid Ecosystem

End-to-End Architecture: From Edge to Rails

PRESENTED BY

Govindaraj Palanisamy

Principal Architect

The Agentic Commerce Revolution

🛒 Traditional Commerce

- Human present at every step
- Manual browsing & selection
- Single synchronous session
- Platform-specific siloes
- High abandonment (~70%)

🚀 Agentic Commerce

- Autonomous agents
- AI-driven discovery
- Asynchronous intent execution
- Cross-platform interoperability
- Reduced friction & abandonment

🚀 New Capabilities in Agentic Commerce:
• Context-aware purchasing (learns preferences) • Multi-merchant optimization (best total value)
• Proactive replenishment (predicts needs) • Negotiation (B2B scenarios) • Asynchronous execution (user delegates, goes away)

Autonomy Levels in Agentic Commerce

Understanding the spectrum: From assisted to autonomous

Level 0
No Autonomy

Human makes all decisions
Agent provides information only
Example: Price comparison tool

Level 1
Suggestion

Agent recommends options
Human approves each action
Example: 'Show me laptops under $1000'

Level 2
Bounded Action

Agent acts within strict limits
Human spot-checks periodically
Example: 'Buy office supplies <$50'

Level 3
Delegated Autonomy

Agent acts independently
Human audits regularly
Example: 'Maintain inventory levels'

Level 4
Full Autonomy

Agent sets and executes policy
Human defines high-level goals
Example: 'Optimize supply chain costs'

Security Controls Scale with Autonomy:
Level 0-1: Basic authentication • Level 2-3: Cryptographic mandates + audit • Level 4: Continuous monitoring + AI safety controls

Why agentic commerce is a “protocol moment”

From click-to-buy → intent-to-buy (delegated, asynchronous, cross-platform)

Open protocols are forming

- UCP: universal discovery + checkout primitives across platforms
- ACP: in-conversation checkout + delegated payments
- AP2: payment-layer trust via mandates + verifiable credentials

New risk surface

- Identity spoofing (agents, tools, merchants)
- Prompt injection → unsafe tool use
- Fraud + disputes without clear consent evidence
- “Shadow automation”: policy drift across hybrid systems

Trust goal

Make agent-initiated transactions: (1) authorized, (2) auditable, (3) non-repudiable, and (4) bounded by customer + regulator expectations — even when systems span legacy + cloud + edge.

Protocol Stack

Agentic Commerce Protocol (ACP)

Checkout

- Powers instant checkout in LLMs.
- Session & Cart Management.
- Delegated Payment Tokens (PCI DSS).
- **Role:**Secure credential transmission layer.

Agent Payments Protocol (AP2)

Trust

- Verifiable Digital Credentials.
- Cryptographic Mandates (Intent/Cart).
- User Presence Signals (HP/HNP).
- **Role:** Non-repudiable proof of consent.

Universal Commerce Protocol (UCP)

Discovery

- Single integration for all AI platforms.
- Transport agnostic (REST, MCP, A2A).
- Supports "Human-Not-Present" flows.
- **Role:**Discovery, Product Feed, Identity Linking

Commerce Examples:

- UCP: 'Find ergonomic chairs <$300' → Product catalog + merchant ratings
- ACP: 'Add to cart, apply loyalty, schedule delivery' → Cart session + final price
- AP2: Present mandate → Payment auth + receipt + tracking

Autonomous agents for B2B transactions

Procurement, invoicing, and negotiations need stronger delegation boundaries

High-value B2B use cases

- Automated procurement (catalog → PO → invoice match)
- Contract / discount negotiation with guardrails
- Inventory replenishment with safety thresholds
- Supplier onboarding + compliance checks

B2B mandate pattern

- Delegation chain: Board/Finance policy → buyer role → agent
- Spend categories + vendor allowlists + approval tiers
- PO/contract hash binding to payment execution
- Step-up approvals for exceptions

Key engineering considerations

- Deterministic "approval paths" (human-in-the-loop where required)
- Explainable decision logs for auditors and counterparties
- Integration with ERP/finance controls and segregation of duties

Agent-to-Agent Commerce Patterns

Beyond human-agent: Enabling autonomous B2B ecosystems

Pattern 1: Human → Agent → Merchant

Current Focus

- User delegates to personal agent
- Agent interacts with traditional checkout
- Merchant systems unchanged
- Trust: User → Agent only

Pattern 2: Human → Agent → Agent → Merchant

Negotiation Layer

- User's agent negotiates with merchant's agent
- Dynamic pricing, terms, delivery
- Mutual VC verification required
- Trust: Agent ↔ Agent via credentials

Pattern 3: Agent → Agent (No Human)

Autonomous B2B

- Inventory agent auto-reorders from supplier agent
- Pre-established contracts + mandates
- Smart contract enforcement
- Trust: Cryptographic + reputation systems

Key Requirement: As agent autonomy increases (Pattern 1→3), identity verification and non-repudiation become critical

Commerce-Specific Threat Scenarios

Mapped to MAESTRO, STRIDE, MITRE ATLAS, and OWASP Top 10

THREAT SCENARIO	MAESTRO LAYER	STRIDE	MITRE ATLAS	OWASP TOP 10 (LLM)
⚠ DISCOVERY PHASE				
Price Manipulation *Agent reads inflated prices*	Layer 2: Data Ops	Tampering	AML.T0002 AML.T0020	LLM09: Overreliance
Poisoned Listings *Indirect prompt injection*	Layer 3: Framework	Tampering	AML.T0051.002	LLM01: Prompt Inj.
Fake Merchants *Spoofed identities*	Layer 6: Ecosystem	Spoofing	AML.T0028	LLM02: Insecure Output
⚠ TRANSACTION PHASE				
Cart Stuffing *Attacker adds items*	Layer 3: Framework	Tampering	AML.T0043	LLM08: Excessive Agency
Address Hijacking *Changes delivery address*	Layer 3: Framework	Elevation of Privilege	AML.T00S1	LLM01 LLM08
Payment Token Theft *MITM intercepts creds*	Layer 4: Deployment	Info Disclosure	AML.T0038	A02 (Web)
⚠ POST-PURCHASE PHASE				
Receipt Forgery *Fake confirmation*	Layer 6: Ecosystem	Repudiation	AML.T0004	LLM09: Overreliance
Subscription Trap *Recurring charges*	Layer 3: Framework	Tampering	AML.T00S4	LLM08: Excessive Agency

Threat model: “confusable deputy” agents

If an agent can call tools, it can be tricked into calling the wrong tool, with the wrong identity, for the wrong amount

Identity spoofing & tool hijack

- Fake agent / fake tool endpoint
- Credential theft (tokens, keys)
- Supply-chain/plugin abuse

Prompt injection → unsafe actions

- Indirect injection via content the agent reads
- Policy bypass (“ignore instructions”)
- Data exfil + payment manipulation

Fraud, disputes, and “who approved?”

- No durable evidence of consent
- Weak user-presence signals
- Poor linkage across parties

Security requirements (what “trustworthy” means)

- Strong agent identity (workload + entity)
- Explicit mandates (scope + TTL) + non-repudiation
- Continuous verification + anomaly detection
- Central policy decision with local enforcement
- Cryptographically verifiable audit trail (end-to-end)
- Privacy-by-design across hybrid data flows

CSA AI CONTROL MATRIX (AICM)

Why AICM here?

AICM provides a vendor-neutral set of control objectives spanning AI in 13 security domains across lifecycles - Design → Dev → Deploy → Retire. Map each commerce component (edge, gateway, mandates, payments) to concrete controls and evidence.

Identity & Access Mgmt

OAuth 2.1 + VC verification + key mgmt

Logging & Monitoring

Traces, immutable audit, anomaly alerts

Data Security & Privacy

Minimize + tokenize + encrypt + retention

Application Security

Prompt injection defenses + tool schemas + model security + sandboxing

Governance, Risk & Compliance

Mandate policies, approvals, audit readiness, AI safety, and regulatory compliance

Threat & Vulnerability Mgmt

Supply-chain controls for tools/plugins + red teaming

Zero Trust for agentic commerce

Never trust agent actions by default – verify identity, policy, and mandate on every step

Strong identity

Workload identity (SPIFFE) (Enterprise Managed) + Decentralized identity (DID with VCs) for untrusted agent interactions

Mandate-based authorization

Explicit consent with scope + TTL; signatures for non-repudiation

Continuous verification

Trust score + anomaly detection + step-up controls

Least privilege

Constrain tools, merchants, amounts, and data access with fine-grained authorization

Auditability

Cryptographic chain of custody + tracing/logging

Implementation hint: treat the AI ready gateway as your “policy choke point”, but keep enforcement local when latency or privacy requires it (edge runtime + service sidecars).

Architecture Risk Mapping

Mapping Architectural Components to Risks and AICM Controls.

User Agent	Prompt Injection (Jailbreak), Identity Spoofing	AIS-04 Secure SDLC IAM-02 Strong Auth	Input sanitization, DID-based wallet signatures, Context barriers.
AI Gateway	Policy Bypass, Model Hallucination, Unauthorized Tool Use	TVM-01 Threat Mgmt LOG-03 Monitoring	Centralized Policy Decision Point (PDP), "LLM as a Judge" guardrails.
Commerce Layer	Fraudulent Transactions, Scope Creep, Replay Attacks	IAM-05 Least Privilege DCS-01 Data Security	Cryptographic Mandates (AP2), Transaction TTL, Nonce tracking.
Infra / Model	Data Poisoning, Model Theft, Supply Chain Attack	MDS-01 Training Security GRC-01 Governance	Signed Model Weights, Trusted Execution Environments (TEE).

Agentic Identity - Enterprise Managed

Short-lived identities for services across heterogeneous environments

SPIFFE identity (SVID) for every component

- Assign SPIFFE IDs to: edge agent service, gateway, mandate verifier, VC verifier, payment adaptor
- Use mTLS (X.509 SVID) or JWT-SVID for service-to-service calls
- Rotate automatically (short TTL) to reduce blast radius

Attestation + issuance (SPIRE)

- Node/workload attestation → issue SVIDs only to verified workloads
- Selector-based registration (K8s, VM, cloud instance, etc.)
- Enables a portable "workload IAM plane" across hybrid environments

mTLS trust chain (example)

SPIRE Server
Issues SVIDs

→

SPIRE Agent
Attests node/workload

→

Gateway
X.509 SVID

→

Mandate svc
X.509 SVID

Agentic ID External: DIDs + Verifiable Credentials (VCs)

Portable “who is this agent?” proof across organizations and ecosystems

Agent entity credential (cross-business)

- Represent the legal entity (merchant, platform, delegated agent provider, user agents)
- Include roles + capabilities + compliance attestations
- Issued by trusted credential providers; verified by merchants, gateways, acquirers

VC verification essentials

- Verify issuer signature + DID resolution
- Check status/revocation lists
- Bind to workload identity (SPIFFE) to prevent token replay
- Prefer short-lived presentations with nonce challenges

Issuer / Holder / Verifier flow (simplified)

Issuer
Credential provider

→ Issue VC

Holder
Agent entity wallet

→ Present VC (nonce)

Verifier
Gateway / merchant / acquirer

From Birth to Decommission: Managing Agent Identity

Issuance of specific verifiable credentials, delegated tokens and budget scopes.

Handshake with Merchant Protocols.

Standard transactional behavior.

Anomaly Detected. Immediate freeze of assets.

Cryptographic shredding of credentials. End of Lifecycle.

Strong authorization - AI Ready Gateway

Externalize decisions (PDP), enforce locally (PEP), align with OAuth 2.1 patterns

OAuth 2.1 + modern client identification

- Prefer secure client auth methods (mTLS / JWT-based)
- Use authorization server metadata for discovery
- Consider Client ID Metadata Documents when pre-registration is not feasible
- Bind tokens to channel/keys where possible

Policy decision point (PDP) + local enforcement

- Gateway calls external authorizer (PDP) with rich context
- PDP evaluates: agent VC, workload SVID, mandate scope, risk signals
- Gateway/sidecars enforce decision (PEP) using ext_authz-style hooks
- Policy-as-code (OPA) enables consistent rules across hybrid

Request path (simplified)

Agent
token + VC + mandate

→

Gateway (PEP)
authN + ext_authz

→

PDP
OPA / rules

→

Service
cart/order/pay

AI-Ready Gateway

Real-time guardrails against injection, fraud, identity spoofing, and unsafe agent behavior

LLM safety controls

- Prompt injection detection
- Tool allowlists + schemas
- Output validation (JSON, PII)
- Policy “guardrails” as code

Routing + evaluation

- Multi-model routing
- Cost/latency steering
- A/B evaluation
- Confidence scoring and fallbacks

Observability

- OpenTelemetry traces
- Central audit logs
- Token/tool usage analytics
- Compliance reporting

Gateway platform options (examples; capabilities matter more than vendors)

- GenAI gateway features in API management platforms (token tracking, governance, caching)
- MCP/tool transformation and registry/catalog for discoverability
- Central enforcement: authN/Z, policies, throttling, schema validation, and audit

MANDATES - Unit of Trust and Verify

Mandate = tamper-evident, signed “contract” capturing scope + consent + amount

A mandate binds: user intent + agent context + merchant/cart constraints + time window + payment method token — producing evidence usable for fraud screening and disputes.

1. User Intent

User delegates authority to Agent.

```
{ "intent": "purchase_ticket", "max_amount": 50.00,
"currency": "USD" }
```

2. Signed Mandate

Agent constructs & signs Mandate.

```
{ "mandate_id": "uuid-123", "scope":
"merchant_category:travel", "ttl": "2024-10-
20T10:00:00Z", "sig": "ecdsa_p256_signature..." }
```

3. Verification

Payment Rail verifies VCs.

```
VERIFY(signature, public_key) CHECK(constraints,
transaction) IF valid THEN process_payment() ELSE
reject()
```

Intent Mandate
Asynchronous pre-authorization (Human-Not-Present).

Cart Mandate
Real-time approval of specific items (Human-Present).

Payment Mandate
Tokenized payment method wrapped with context.

User Consent & Mandate Creation Flow

From user intent to cryptographic authorization

1

User Intent

"Find me the best standing desk under $500"

User

2

Agent Analysis

Analyzes intent:
- Category: Furniture/Office
- Price constraint: ≤$500
- Quality priority: 'best'

Agent

3

Mandate Proposal

Category: Furniture/Desk
Max: $500 | Merchants: [5 approved]
Timeline: 7 days
Approval: Required before purchase

Agent

4

User Authorization

Reviews terms
Signs with biometric/hardware key
Binds payment method

User

5

Execution

Searches within mandate
Returns top 3 options
User selects → Agent completes

Agent

Critical: Mandate is cryptographically signed (ECDSA-P256) with hardware-backed key. This creates non-repudiable evidence of user consent.

Hybrid integration: Privacy-by-Design + Secure-by-Design

Blend legacy platforms and emerging AI systems without expanding the blast radius

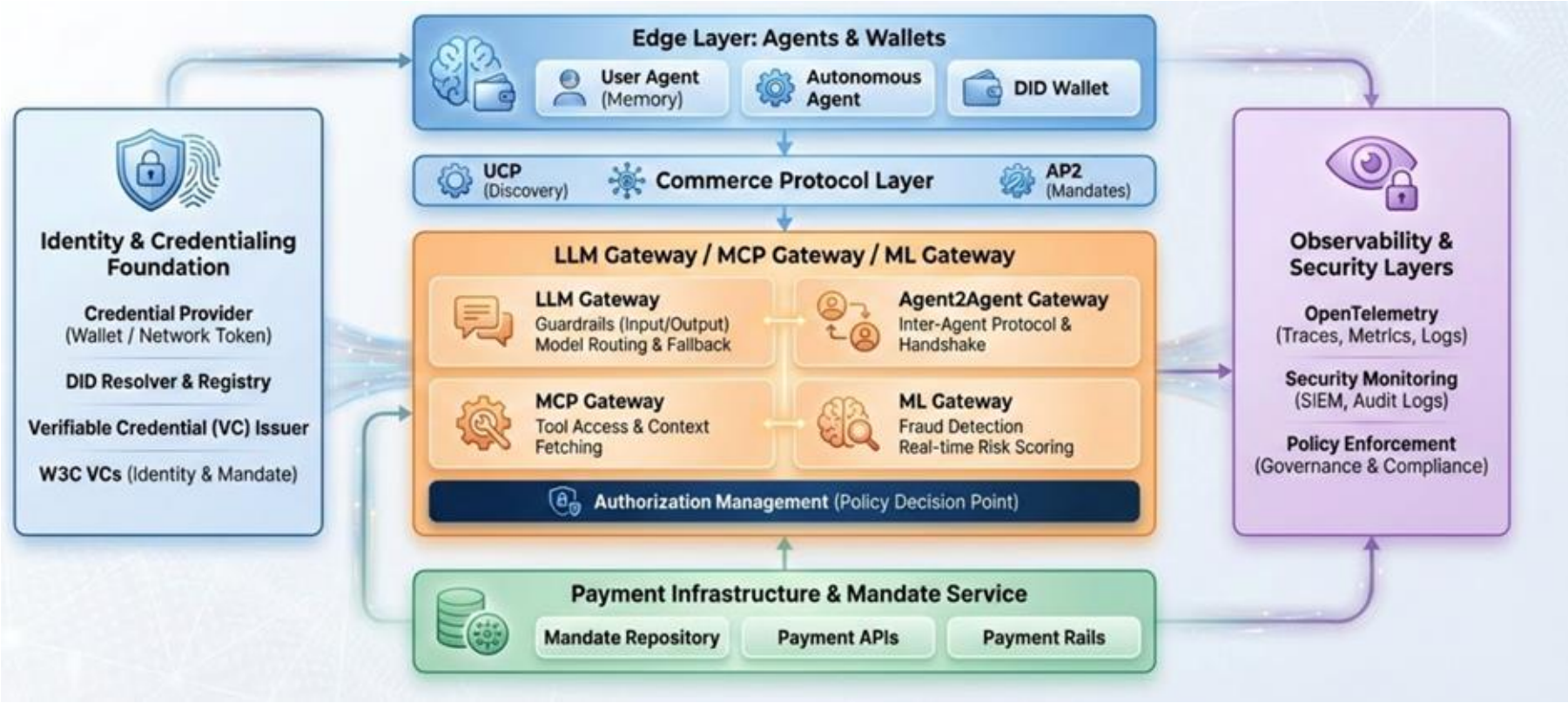
Privacy-by-Design controls

- Data minimization (only what the tool needs)
- Tokenization for payment methods (no raw PAN exposure to agents)
- Pseudonymization for analytics; encrypt sensitive logs
- Purpose limitation and retention policies for mandates/evidence

Secure-by-Design integration patterns

- Strangler pattern to wrap legacy with governed APIs
- Protocol translation at the gateway (REST/MCP/A2A)
- Sidecar-based enforcement for legacy services (mTLS + authZ)
- Break-glass and rapid revocation for compromised agents

Agentic Commerce - Blueprint



STRATEGIC RISK MITIGATION WITH AICM

The CSA AI Control Matrix (AICM) provides a structured methodology to mitigate risks across the entire lifecycle of an Agentic Commerce system.

1. Prevent

Design & Build Phase

Focus on "Security by Design" to stop threats before they manifest.

- **AIS-04:** Secure SDLC (Input validation).
- **GRC-01:** Policy Enforcement (Acceptable
- **IAM-05:** Least Privilege (Scope limits).
- **DCS-01:** Data Protection (Encryption).

2. Detect

Run & Operate Phase

Real-time monitoring to identify anomalies and active attacks.

- **LOG-03:** Security Monitoring (SIEM).
- **TVM-01:** Threat Management (Anomaly
- **MDS-03:** Adversarial Robustness (Jailbreak detection).
- **AIS-05:** Output Handling (Hallucination checks).

3. Respond

Audit & Improve Phase

Post-incident analysis and continuous compliance verification.

- **AUD-02:** Non-Repudiation (Signed
- **GRC-05:** Third-Party Risk (Vendor
- **IAM-01:** Identity Inventory (DID Registry).
- **SEF-01:** Incident Response (Forensics).

Key Takeaway: The AICM isn't just a checklist; it's a lifecycle framework. By mapping controls to specific phases (UCP discovery, ACP checkout, AP2 payment), organizations can achieve granular risk coverage that standard IT controls miss.

Shared Infrastructure & Supply Chain

Applying "other" AICM domains to mitigate systemic and operational risks.

AICM Domain	Control ID	Control Name	Agentic Implementation Strategy
STA	STA-01	Supply Chain Risk	**Agent Allowlisting:** Gateways enforce an allowlist of approved "Agent Builders" or "Wallet Providers" based on compliance certification status.
IVS	IVS-06	Network Security	**Micro-Segmentation:** Agent runtimes are isolated in their own VPCs or subnets. A compromised agent cannot pivot to the payment vault.
LOG	LOG-03	Security Monitoring	**OpenTelemetry Tracing:** Full distributed tracing (OTEL) visualizes the request path: User → Agent → Gateway → Merchant → Rail. Identifies latency injection or data exfiltration.
TVM	TVM-01	Threat Detection	**Behavioral Analytics:** The AI Gateway monitors agent velocity (e.g., buying 500 items in 1s) and pattern anomalies to trigger circuit breakers.
MDS	MDS-01	Model Supply Chain	**Signed Weights:** If using local SLMs for routing, model weights must be signed to prevent tampering or poisoning attacks.

Universal Commerce Protocol (UCP) - Discovery Layer

AICM Domain	Control ID	Control Name	Agentic Implementation Strategy
AIS	AIS-04	Input Validation	**Strict Schema Validation:** UCP requests must adhere to strict JSON schemas. Free-text "intent" fields must pass through an LLM Guardrail to detect jailbreak attempts.
AIS	AIS-05	Output Handling	**Hallucination Checks:** Search results are cross-referenced against the raw product catalog to ensure price/inventory data is accurate.
MDS	MDS-03	Adversarial Robustness	**Feed Sanitization:** Merchant product feeds are scanned for "Indirect Prompt Injection" attacks (e.g., hidden text manipulating buyer agents).
LOG	LOG-01	Event Logging	**Intent Ledger:** Discovery queries and agent decisions are logged to a tamper-evident ledger for auditability.

Agentic Commerce Protocol (ACP) - Checkout Layer

AICM Domain	Control ID	Control Name	Agentic Implementation Strategy
DCS	DCS-01	Encryption	**Payload Encryption:** All PII (shipping/contact info) in ACP payloads is encrypted using the Merchant's public key (HPKE) at the Edge/Wallet level.
IAM	IAM-05	Least Privilege	**Scoped Sessions:** ACP tokens are restricted to specific "Cart Contexts." An agent authorized for Cart A cannot access Cart B.
TVM	TVM-02	Vuln. Mgmt	**Sandboxed Runtimes:** "Checkout Agents" run in ephemeral, isolated containers (e.g., Wasm) to prevent cross-session data leakage.

Agent Payments Protocol (AP2)

Focus: Authorization, cryptographic consent, and secure payment execution.

AICM Domain	Control ID	Control Name	Agentic Implementation Strategy
IAM	IAM-01	Identity Inventory	**DID Registry:** All Agents must possess a Decentralized Identifier (DID) anchored in a verifiable registry. Unknown DIDs are rejected.
IAM	IAM-02	Strong Auth	**Cryptographic Mandates:** Auth is an ECDSA (P-256) signature from a hardware-backed key (Secure Enclave). "Human Presence" flags are bound to the signature.
AIS	AIS-03	API Security	**Replay Protection:** AP2 Mandates include strictly enforced nonce and exp (expiration) timestamps to prevent replay attacks.
GRC	GRC-01	Policy Enforcement	**Mandate Scoping:** The Mandate enforces hard limits (e.g., MaxAmount, MerchantCategory). Policy engines reject transactions exceeding signed scope.
AUD	AUD-02	Non-Repudiation	**Signed Receipts:** The payment gateway returns a counter-signed receipt. User Mandate + Gateway Receipt = Non-repudiable audit trail.

Edge computing: safer, faster agent runtime

Run “small” controls close to the user; use the gateway for central policy + audit

Why put controls at the edge?

- Lower latency for interactive shopping
- Data minimization (keep sensitive context local)
- Resilience when gateway is degraded
- Early rejection of obviously unsafe tool calls

Edge pattern (recommended)

- Small language model (SLM) for intent classification + schema checks
- Agent Guardrails
- Fraud heuristics (velocity, device signals)

Concrete example: in-browser / on-device inference

- Run a small model locally for “safety parsing” (inputs/outputs/tool args), not for the whole commerce workflow
- Use the gateway for mandate verification, VC checks, and ecosystem integrations (PSPs, acquirers, networks)
- Treat edge results as advisory signals; central policy remains source of truth

Merchant Acquirer: Critical Trust Anchor

Mandates + evidence packaging + network signals improve authorization + reduce chargebacks

Why acquirers matter more in agentic flows

- Acquirers sit in the dispute path between issuer and merchant
- They aggregate evidence and submit representment
- They monitor merchant risk and chargeback ratios
- They can enforce “agentic requirements” as part of onboarding

What to integrate (vendor neutral)

- Attach mandate evidence (hashes, signatures, HP/HNP) to payment context
- Share “agent involvement” indicators downstream (AP2-style)
- Use payment brand services where available for enhanced risk scoring
- Standardize evidence packaging for chargebacks

Dispute readiness checklist

- Persist: mandate + VC proof + transaction binding + gateway decision record
- Include trace IDs (end-to-end) for rapid evidence retrieval
- Implement step-up for high-risk mandates (e.g., re-auth, second factor)
- Define retention + privacy rules for stored evidence

Success metrics (technical first)

Measure security, reliability, and evidence quality – not just conversion

Security

- Mandate verification success rate
- Policy violation rate (blocked tool calls)
- Unauthorized access
- Mean time to detect/respond to compromise

Reliability

- Gateway p95 latency
- Transaction success rate
- Fallback effectiveness (graceful degradation)

Dispute readiness

- Evidence completeness score
- Time to retrieve evidence packet
- Chargeback ratio for agentic flows

Governance

- AICM control coverage (by component)
- Audit findings (critical/major)
- Model/tool inventory accuracy
- Scorecards

BUILDING THE FUTURE OF TRUST

Trust is the Currency of Agentic Commerce

Open Protocols

UCP, ACP, and AP2 ensure universal interoperability and prevent vendor lock-in.

Zero Trust + AICM

Comprehensive security from the network layer to the model prompts.

Payment Anchors

Acquirers and Payment Rails remain the ultimate trust anchors for payment security and dispute resolution.

Security and Privacy by Design

Security and privacy must be architectural decisions, not afterthoughts.

SUMMIT Q&A SESSION
QUESTIONS
ANSWERS

THANK YOU